Лабораторная работа 1

Восстановление паролей в Windows XP

В работе я проверил, как длина цифрового пароля влияет на время его восстановления. Основной результат: пароль **4827193659** удалось восстановить за **7 минут 56 секунд**. Это укладывается в интервал 5-15 минут, предложенный в задании.

Что использовал

Oracle VirtualBox 7.1.6, Windows XP 32 бит и Cain & Abel. Для опытов создал отдельные учебные учётные записи lab_test, lab_speed и lab_final. Во всех запусках выбрал полный перебор NTLM-хеша и цифровой алфавит 0123456789.

Цель - измерить скорость перебора, подобрать параметры пароля для приемлемого времени восстановления и рассчитать примеры для часа, суток, недели, месяца и года.

Как проходили опыты

Сначала проверил короткий пароль. Для lab_test задал 573921 и длину ровно 6 символов. Получилось 1 000 000 вариантов. Программа нашла пароль и показала «1 of 1 hashes cracked». Время этого короткого запуска отдельно не измерял. Настройки и результат приведены на рисунках 1 и 2.

Затем измерил скорость. Для lab_speed использовал учебный пароль 937184620583 и длину 12 символов. Такой запуск нужен был для замера скорости; до полного завершения его не доводил. Во время работы поле Key Rate показывало **21 021 990 Pass/Sec** (рисунки 3 и 4).

В основном опыте для lab_final задал пароль 4827193659 и длину 10. При найденной скорости полный проход оценивался примерно в 8 минут. После запуска засёк время секундомером. Пароль был найден, итоговое время - **476 секунд** (рисунки 5 и 6).

Опыт	Длина	Число вариантов	Результат
Короткий пароль	6	10^6	573921 найден
Замер скорости	12	10^{12}	21 021 990 проверок/с
Основной	10	10^{10}	4827193659 найден за 7 мин 56 с

Фактическое время основного опыта записано по секундомеру. Итоговый скриншот подтверждает найденный пароль; само поле Key Rate после завершения уже пустое.

Расчёты времени перебора

Для расчётов взял измеренную скорость V = 21 021 990 проверок/с. Она считается постоянной; это упрощение для оценки полного прохода пространства поиска.

$$N = A^L;\ T_{\max} = N / V;\ T_{\text{ср}} \approx N / (2V);\ H = \log_2 N$$

Здесь A - размер алфавита, L - фиксированная длина, N - число кандидатов, H - энтропия равномерного выбора в битах. Среднее время относится к равновероятному паролю и перебору без повторений. Для маски N равно произведению размеров алфавитов отдельных позиций.

Для основного опыта: $N = 10^{10}$; $T_{max} = 10^{10} / 21\,021\,990 \approx$ **475,69 с**; $H = 10 \log_2 10 \approx$ **33,22 бита**. Измеренные 476 с близки к оценке полного прохода. При этом время нахождения конкретного пароля зависит от его позиции в переборе, а скорость между запусками может меняться.

Чтобы полный проход занимал заданное время t, нужно пространство N = Vt. Месяц здесь принят равным 30 суткам, год - 365 суткам.

Срок	Время t в секундах	Число вариантов Vt	H в битах
1 час	3 600	75 679 164 000	36,14
1 сутки	86 400	1 816 299 936 000	40,72
1 неделя	604 800	12 714 099 552 000	43,53
1 месяц	2 592 000	54 488 998 080 000	45,63
1 год	31 536 000	662 949 476 640 000	49,24

Ниже подобрал примеры масок с близкими сроками. Обозначения: d - цифры (10), l - строчные латинские буквы (26), a - строчные буквы и цифры (36), b - латинские буквы обоих регистров (52), c - буквы обоих регистров и цифры (62), p - печатные ASCII вместе с пробелом (95). Степень показывает число позиций; знак + означает соединение частей.

Ориентир	Маска и пример строки	Число вариантов N	Полный проход N/V
Около часа	a^7 k7v2m9q	78 364 164 096	1 ч 2 мин 8 с
Около суток	$a^2 + c^4 + p$ k7G2mQ!	1 819 262 488 320	1 сут 2 мин 21 с
Около недели	$c^4 + p^3$ G7mQ!#?	12 668 861 078 000	6 сут 23 ч 24 мин 8 с
Около месяца	$l^9 + d$ qvmrtnkza7	54 295 036 789 760	29 сут 21 ч 26 мин 13 с
Около года	$b + c^4 + p^3$ qG7mQ!#?	658 780 776 056 000	362 сут 16 ч 54 мин 58 с

Эти пять сроков рассчитаны, а не измерены отдельными запусками. Маска предполагается известной заранее, а символы - случайными и равновероятными в своих алфавитах. Пример строки сам по себе не гарантирует такой срок нахождения. Для оценки среднего времени значения полного прохода нужно примерно разделить на два.

Ответы на контрольные вопросы

В каком виде хранятся пароли и зачем нужен SYSKEY

Для локальных учётных записей Windows XP использует SAM. Файл находится в %SystemRoot%\System32\Config\SAM. В нём хранятся защищённые представления хешей, а не открытый текст паролей. NT-хеш - MD4 от пароля в кодировке UTF-16LE, длина результата 128 бит. Он не содержит индивидуальной соли.

LM - старая схема: пароль переводится в верхний регистр, дополняется до 14 байт и делится на две части по 7 байт. Каждая часть задаёт DES-ключ для обработки фиксированной строки; два результата объединяются в 16 байт. Потеря регистра и независимые половины упрощают поиск. SYSKEY в старых Windows дополнительно защищал хеши при хранении с помощью системного ключа. Это отдельная защита хранения, а не соль NT-хеша.

Основные режимы восстановления паролей

Режим	Плюс	Минус
По словарю	Быстро проверяет вероятные слова	Пароля может не быть в словаре
Полный перебор	Покрывает всё заданное пространство	Время быстро растёт с длиной
Гибридный	Проверяет слова с добавлениями и заменами	Зависит от словаря и правил
По маске	Сокращает поиск по известной структуре	Неверная маска исключит нужный пароль

В методичке также упомянуты радужные таблицы: часть вычислений сделана заранее, но таблицы требуют места и подходят только к определённым алгоритмам и пространствам. Индивидуальная соль мешает применять одну таблицу сразу ко всем паролям.

Какой пароль можно считать простым или сложным

В этой работе простой пароль - тот, который удаётся восстановить за приемлемое время на выбранном компьютере. Сложный потребует заметно больше времени. В методичке приведены исторические рекомендации Microsoft: длина от 7 символов, разные группы символов и отсутствие личных данных и популярных слов. Для реальной стойкости важны длина и случайность: предсказуемое слово с цифрой остаётся удобной целью для словарных правил.

Что такое подсоленный пароль

Обычно так называют хранение результата функции от пароля с добавлением индивидуальной соли. Соль сохраняют вместе с результатом; секретной она быть не обязана. Разные соли дают разные результаты для одинаковых паролей и мешают использовать готовые таблицы для массовой проверки. Для современного хранения нужна также затратная функция, например Argon2id, scrypt или PBKDF2. У обычного NT-хеша соли нет.

Вывод

Я проверил восстановление короткого цифрового пароля, измерил скорость и провёл основной опыт с длиной 10 символов. Пароль 4827193659 был найден за 7 минут 56 секунд. При увеличении длины цифрового пароля на один символ число вариантов возрастает в 10 раз: для длины 12 полный проход уже оценивается примерно в 13,21 часа. Расчёты также показали, что знание структуры пароля заметно меняет объём поиска. Мои результаты относятся к NT-хешам и выбранному режиму; для другого алгоритма скорость нужно измерять заново.

Источник задания: методические указания «Восстановление паролей в Windows XP», лабораторная работа 1, с. 5-7. Скриншоты опытов приведены далее.

Скриншоты предварительного опыта

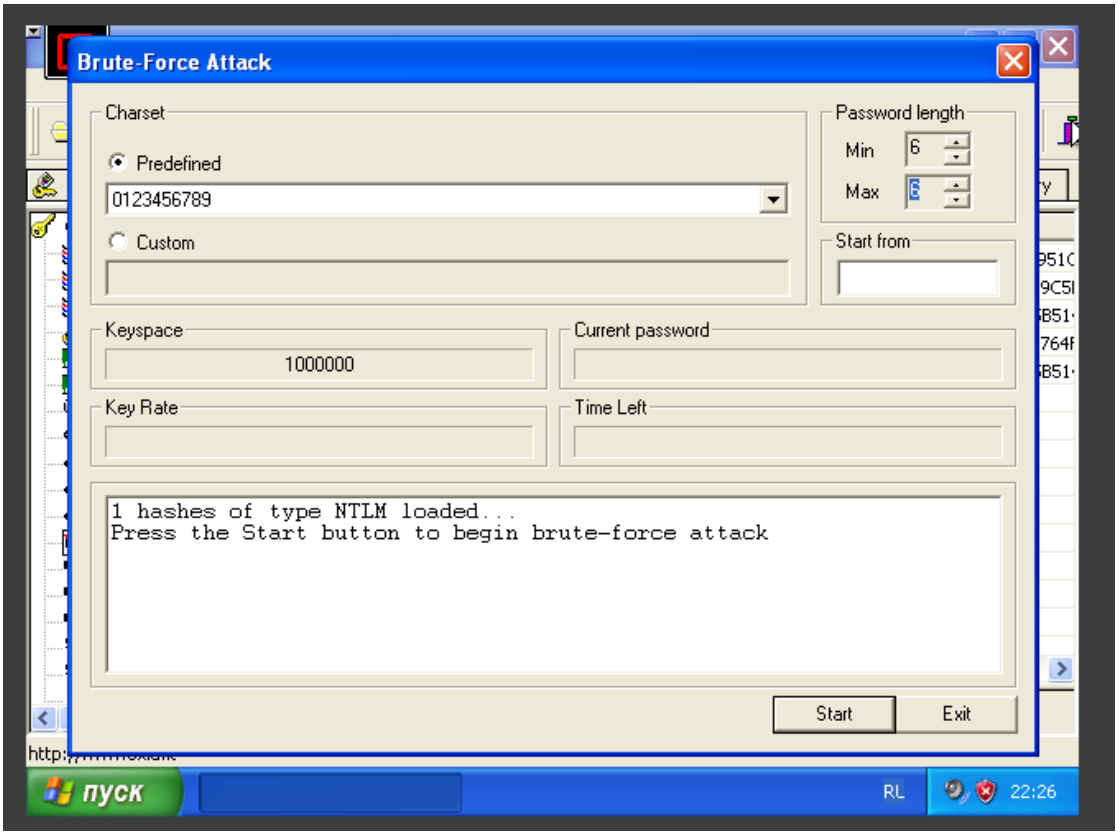


Рисунок 1 - NTLM, цифровой алфавит и длина 6

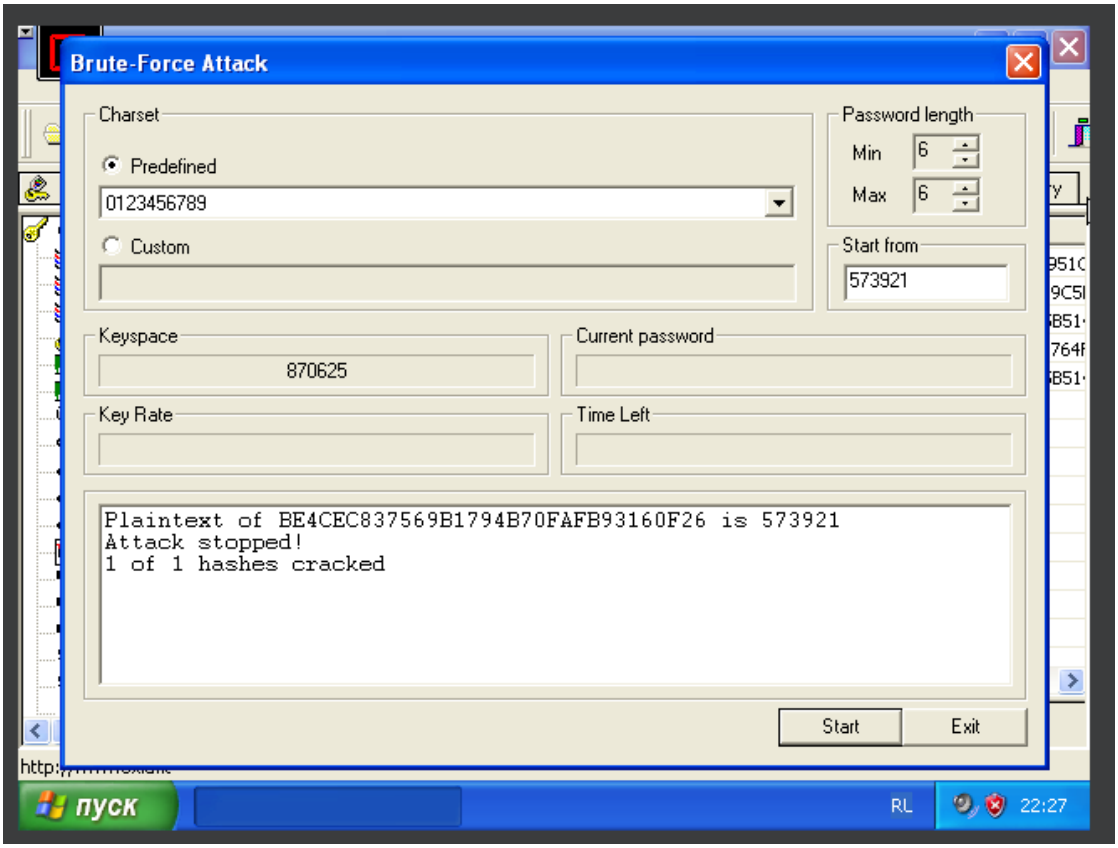


Рисунок 2 - Восстановлен пароль 573921

Скриншоты замера скорости

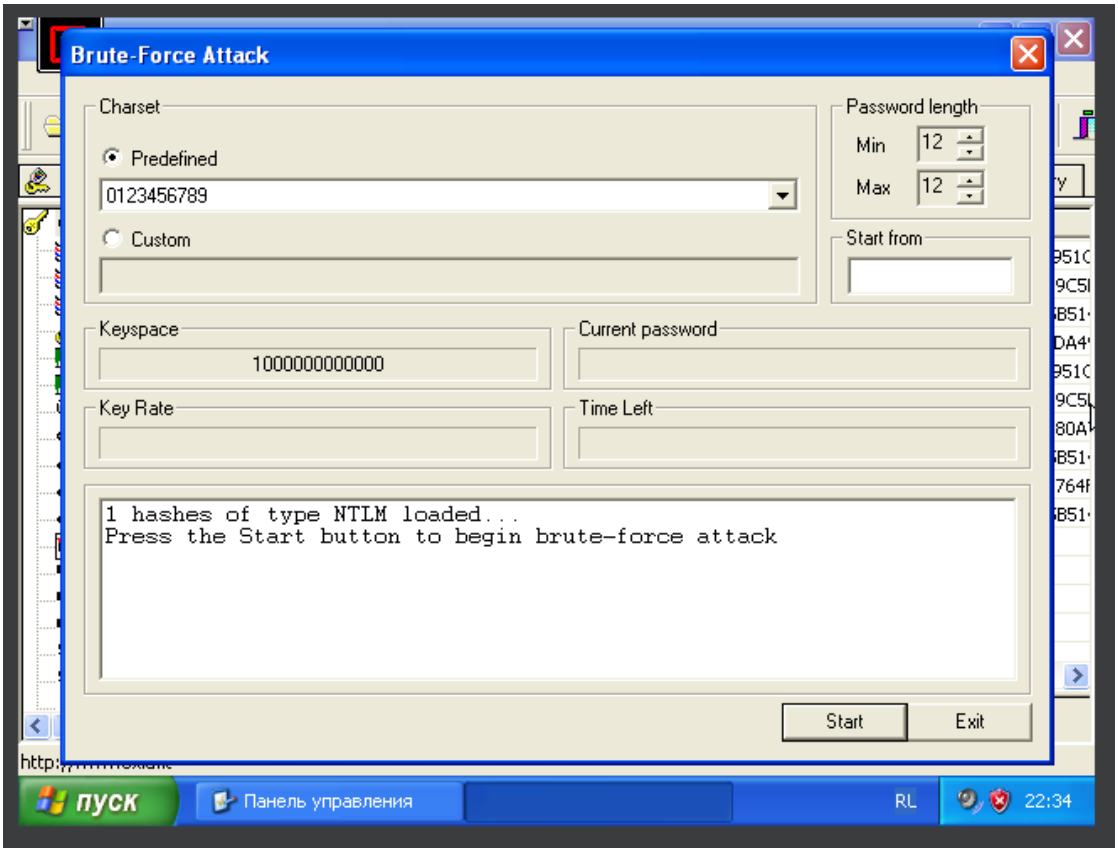


Рисунок 3 - Для замера выбрана длина 12

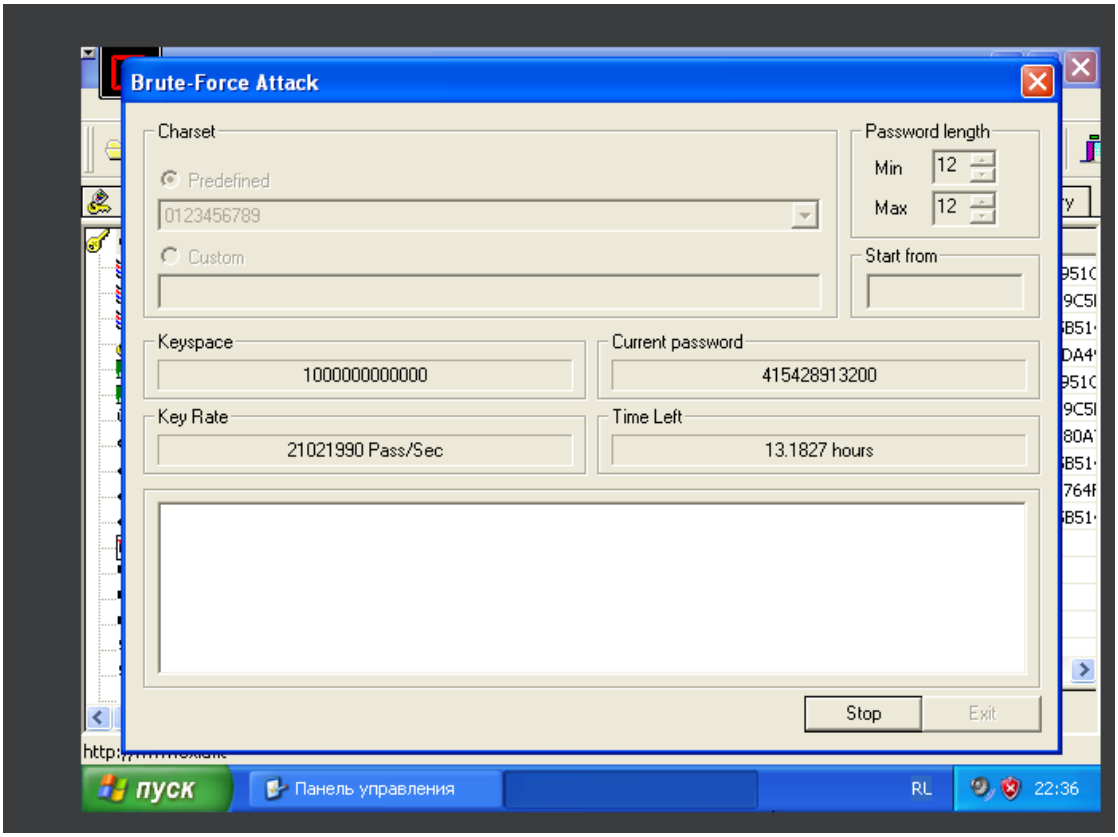


Рисунок 4 - Key Rate показывает 21 021 990 Pass/Sec

Скриншоты основного опыта

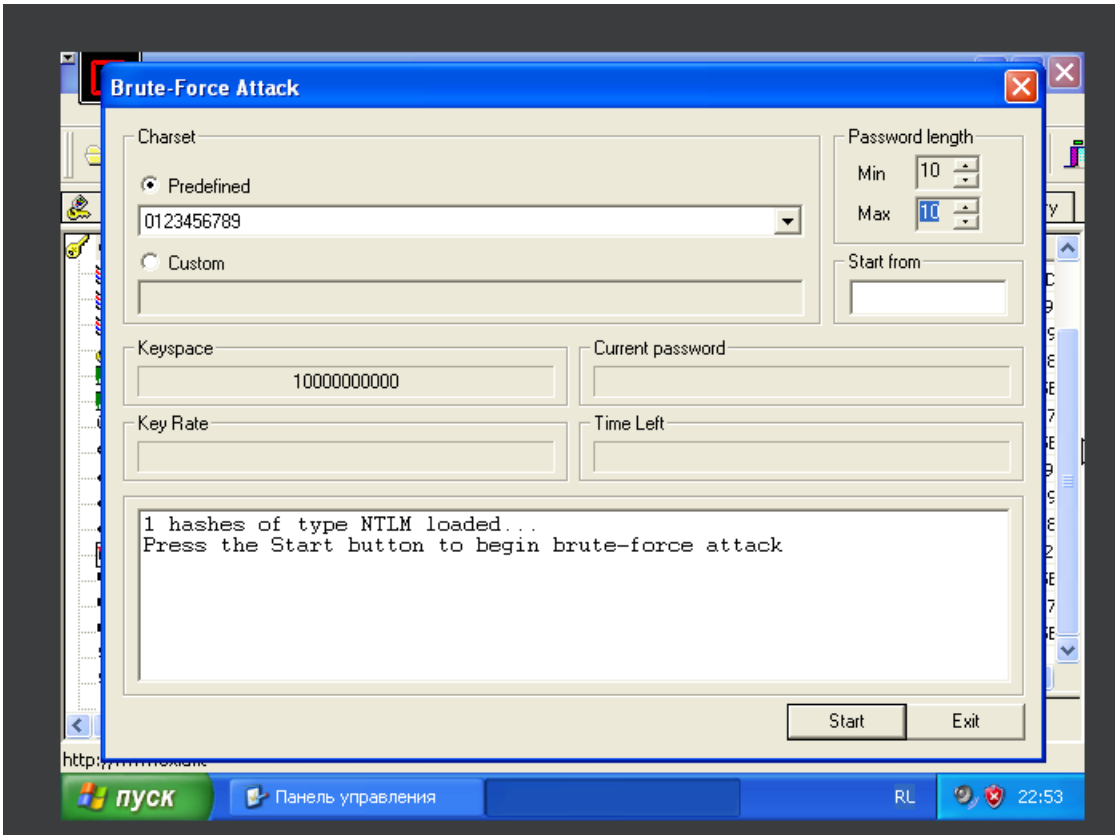


Рисунок 5 - Цифровой алфавит и длина 10

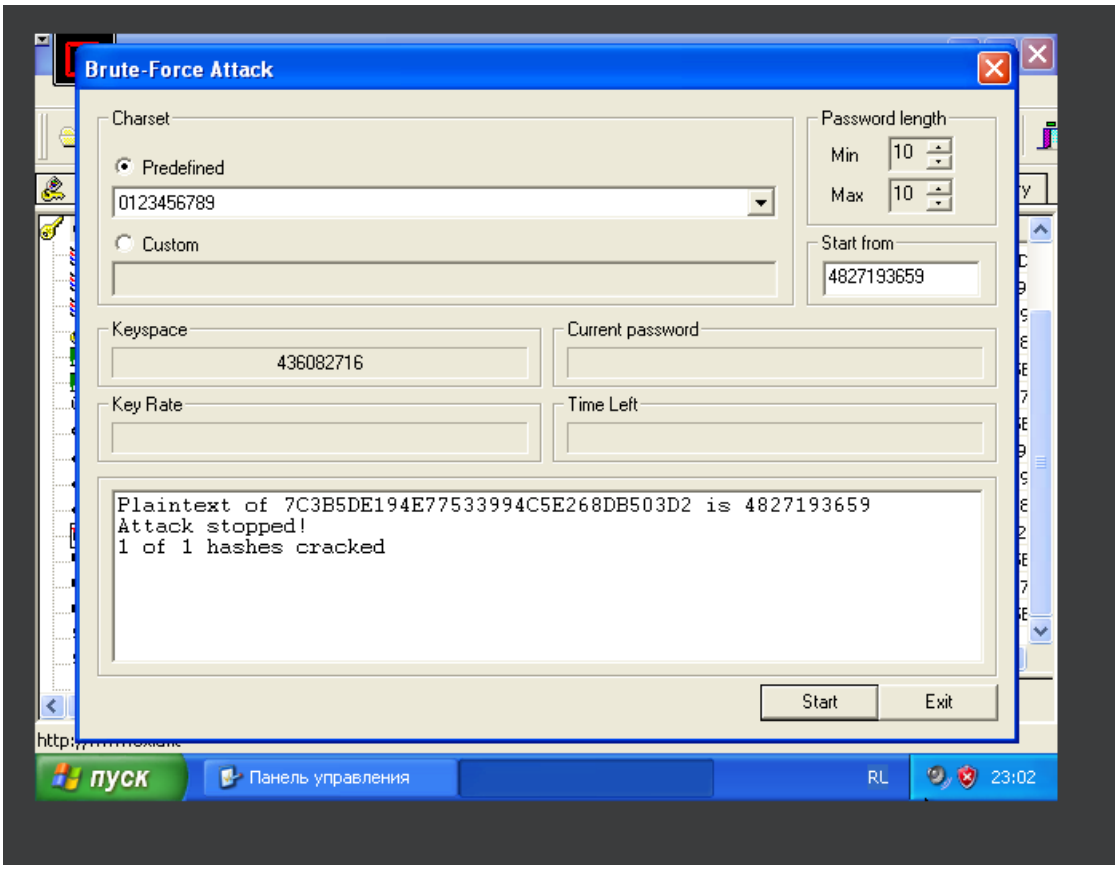


Рисунок 6 - Восстановлен пароль 4827193659